

LM 的 PPT 会标注 LM, PPT 默认为 CY 的 PPT。

红色为待补充的部分

蓝色斜体为 PPT 中提到的出题类型

第二章 网络攻击行径分析

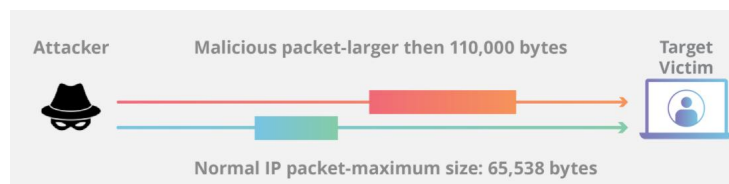
破坏型攻击

P9 定义, 常见类型 (病毒攻击, Dos)

Dos 常见类型和手段

- Ping of Death

PPT+书上都有原理 *ping -s (设置数据包大小) IP_Addr*



防御方法: 对重新组装过程添加检查, 以确保在分组重组后不会超过最大数据包大小约束; 创建一个具有足够空间的内存缓冲区来处理超过最大准则的数据包。

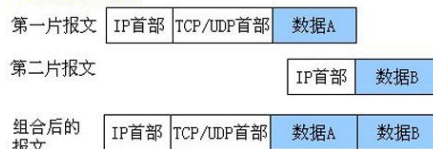
- IGMP/ICMP Flood

防御方法: 被攻击目标可以在其网络边界直接过滤并丢弃 ICMP/IGMP 数据包使攻击无效化。

- Teardrop

第一个包的偏移量为 0, 长度为 N, 第二个包的偏移量小于 N。为了合并这些数据段, TCP/IP 堆栈会分配超乎寻常的巨大资源, 从而造成系统资源的缺乏, 甚至机器重新启动。

正常分片IP报文



Teardrop攻击报文分片



防御方法:

1. 网络安全设备将接收到的分片报文先放入缓存中, 并根据源 IP 地址和目的 IP 地址对报文进行分组, 源 IP 地址和目的 IP 地址均相同的报文归入同一组, 然后对每组 IP 报文的相关分片信息进行检查, 丢弃分片信息存在错误的报文。

2. 为了防止缓存溢出, 当缓存快要存满时, 直接丢弃后续分片报文。

- UDP Flood

攻击端口为业务端口: 根据该业务 UDP 最大包长设置 UDP 最大包大小以过滤异常流量。

攻击端口为非业务端口: 丢弃所有 UDP 包; 建立 UDP 连接规则, 要求所有去往该端口的 UDP 包, 必须首先与 TCP 端口建立 TCP 连接。这种方法需要专业的防火墙或

其他防护设备支持。

- SYN Flood

图见 PPT

利用型攻击

P11

- 口令猜测

首先获得账号（使用 Finger 命令查询时会保存用户名；社工-email 等），然后破译口令。

网络监听：很多协议没有采用任何加密或身份认证技术（Telnet、FTP、HTTP、SMTP 等传），用户帐户和密码信息都是以明文格式传输的，此时若攻击者利用数据包截取工具便可很容易收集到帐户和密码。

缓冲区溢出：编制有缓冲区溢出错误的 SUID 程序来获得超级用户权限。

- 特洛伊木马

基于 C/S 结构的远程控制程序，是一类隐藏在合法程序中的恶意代码，这些代码或者执行恶意行为，或者为非授权访问系统的特权功能而提供后门。

传染方式:通过电子邮件附件发出，捆绑在其他的程序中。

病毒特性:会修改注册表、驻留内存、在系统中安装后门程序、开机加载附带的木马。

防范措施:不下载和运行来历不明的程序，不打开不明来历的邮件附件。

- 缓冲区溢出

信息收集型攻击

信息收集方法：

1. 从一些社会信息入手：通过社工的方式，查找到目标的一些信息。可以参考 CYPPT，上面有很多信息收集的内容。
2. 找到网络地址范围：比如通过社交软件获得目标所在地，获得大致 ip 范围。通过扫描技术，地址扫描
3. 找到关键的机器地址：通过扫描技术，地址扫描
4. 找到开放端口和入口点：端口扫描技术（以上都在课本 p12）
5. 找到系统的制造商和版本：体系结构探测（课本 p13）

P12 扫描技术

Nmap: P35

进行 ping 扫描，打印出对扫描做出响应的主机,不做进一步测试

nmap -sP 192.168.1.0/24

仅列出指定网络上的每台主机，不发送任何报文到目标主机：

nmap -sL 192.168.1.0/24

探测目标主机开放的端口，可以指定一个以逗号分隔的端口列表(如-PS22, 23, 25, 80):

nmap -PS 192.168.1.234

使用 UDP ping 探测主机：

nmap -PU 192.168.1.0/24

使用频率最高的扫描选项：SYN 扫描,又称为半开放扫描，它不打开一个完全的 TCP 连接，执行得很快：

nmap -sS 192.168.1.0/24

当 SYN 扫描不能用时，TCP Connect()扫描就是默认的 TCP 扫描：

nmap -sT 192.168.1.0/24

UDP 扫描用-sU 选项,UDP 扫描发送空的(没有数据)UDP 报头到每个目标端口：

nmap -sU 192.168.1.0/24

确定目标机支持哪些 IP 协议 (TCP, ICMP, IGMP 等):

nmap -sO 192.168.1.19

探测目标主机的操作系统：

nmap -O 192.168.1.19

nmap -A 192.168.1.19

- 地址扫描
- 端口扫描
- 反响映射
- 慢速扫描
- 漏洞扫描

网络欺骗攻击

P13 （扩展答）第七章 欺骗攻击

- DNS 欺骗攻击
- 电子邮件欺骗
- Web 欺骗
- IP 欺骗

攻击步骤

P17 图 2-1

准备

- 确定攻击目的 P16 + PPT
- 准备攻击工具 P18
- 收集目标信息 P18 结合扫描技术答

实施

- 隐藏自己位置（使用他人 IP）
- 登录主机 结合利用型攻击三点答（口令猜测/特洛伊木马/缓冲区溢出）
- 窃取网络资源和特权（根据具体问题的攻击目的答）

善后

Windows-Unix

为什么要进行善后工作？ P20

第三章 网络侦查技术

网络扫描

P30 3.1.1 - 扫描器的定义、功能 (PPT)

地址扫描

端口扫描

前三个例子 PPT 上有图，答题时把图画上去。P32 有代码例子扫一眼 (LMPPT 也有)

- Connect()
- TCP SYN
- TCP Fin

其它的对着 PPT 看一下特点就行。

漏洞扫描

网络监听

嗅探器

P43

交换式以太网

P44 一定程度低于 Sniffer 攻击。

ARP 欺骗 (防御方法?)

建立正确的 ARP 映射关系、检测并过滤伪造的 ARP 报文，保证经过其转发的 ARP 报文正确合法；

抑制短时间内大量 ARP 报文的冲击。

在无线网络中，防御 ARP 欺骗的有效方法是网络管理员分别在主机或接入点上和路由器或控制器上对 IP 和 MAC 地址进行静态映射绑定。(ARP 欺骗是通过重复应答实现的，那么只需要在主机添加一条静态的 ARP 映射，这样就不需要询问网关 MAC 地址了；对于网关欺骗还需要在网关中也添加一条到主机的静态 ARP 映射。)

共享式以太网

P39 共享以太网的四种工作模式：混杂模式下可以收听所有报文。

P40 设置为混杂模式的方法，代码扫一眼

防范方法

P45

需要基于书上的例子展开答。

- 确保以太网整体安全性
- 采用加密技术 (例子?)

如使用 RSA 加密算法等。缺点是影响数据传输速度以及使用一个弱加密术比较容易被攻破。系统管理员和用户需要在网络速度和安全性上进行折中。

- 交换机（原理？例子？）

启用并正确配置交换机的安全机制。将交换机物理端口和 MAC 地址静态绑定，限制交换机单个物理端口可以动态绑定的 MAC 地址数量。以交换式集线器代替共享式集线器对局域网的中心交换机进行网络分段后，局域网监听的危险仍然存在。这是因为网络最终用户的接入往往是通过分支集线器而不是中心交换机，而使用最广泛的分支集线器通常是共享式集线器。这样，当用户与主机进行数据通信时，两台机器之间的数据包（称为单播包 Unicast Packet）还是会被同一台集线器上的其他用户所监听。因此，应该以交换式集线器代替共享式集线器，使单播包仅在两个节点之间传送，从而防止非法监听。当然，交换式集线器只能控制单播包而无法控制广播包（Broadcast Packet）和多播包（Multicast Packet）。但广播包和多播包内的关键信息，要远远少于单播包。

- 划分 VLAN

划分 VLAN 虚拟局域网，可以将以太网通信变为点到点通信，从而防止大部分基于网络监听的入侵。

- 一次性口令

- Kerberos 等第三方服务提供认证机制

检测手段

P46

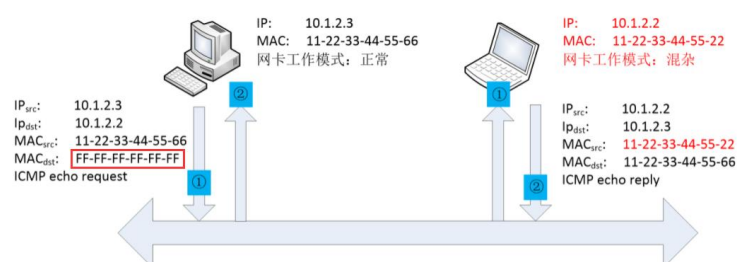
- 反应时间

- DNS 测试

地址反向解析：通过 IP 查域名

- Ping

由于在正常模式下，主机只接收目的 MAC 地址是自己的数据包，其他将一律丢弃；而在混杂模式下，网卡并不检查目的 MAC 地址，对所有的数据包都来者不拒。所以，我们只需要构造并发送一个：疑似待排查为混杂模式目标主机的 IP 目的地址和与其真实 MAC 地址不同的虚假 MAC 目的地址 ICMP 回显请求（echo request）数据包，如果收到应答，则说明该被排查的目标主机网卡当前正工作于混杂模式，即当前网络中可能存在监听者。



- ARP 数据包（原理）

首先发送一个 ARP 广播包，这样 ARP 缓存表中便包括了所有在线的主机 IP 到 MAC 地址的映射，随后再发送一个非广播 ARP，接着查看当前 ARP 缓存表，检查两表是否一致，若有异常则说明存在监听。其中 `arp -a` 命令用来查看当前 ARP 缓存表。（ARP 举例别用 FF-FF-FF-FF-FF-FF，那是 ARP 广播包。原理也是混杂模式不看 MAC_addr）

```
> arp -a
Internet 地址      物理地址      类型      正常状态
10.0.2.2      52-54-00-12-35-02      动态

> arp -a
Internet 地址      物理地址      类型      状态
10.0.2.2      25-35-FE-12-35-12      动态
```

口令破解

P46 + PPT 字典文件通常包含数据内容、类型知道即可。

第四章 拒绝服务攻击

概述

P56 + PPT 定义

P57 4.1.2 DoS 攻击思想和方法要从两个角度答全。

分类

P57

物理破坏 P60

配置文件修改和破坏 P60

资源消耗破坏

消耗网络资源实例：

- Smurf 广播风暴攻击 (P67 前年考过)
P58+PPT (ICMP 协议的解释见 PPT 第二章 7)
(应对方式需要写详细一点) 结合 P68 看一下有什么需要补充的
 1. 阻断虚假源地址 (对应书上 3)
 2. 阻断 WAN 广播包 (对应书上 1)
 3. 求助 ISP, 阻断某 IP 网段 (对应书上 2)
- TCP SYN 攻击 P61 + LMPPT (~~PPT 上提了防御方式, 结合 P66 看一下有什么需要补充~~)
- ACK Flood 攻击 (~~PPT 上提了防御方式, 详细一点~~)
僵尸主机多的话怎么办? 可以用防范 DDoS 的思路答。
握手的第二步是 SYN ACK 数据包。通常, 服务器在响应来自客户端设备的 SYN 数据包时发送此 SYN ACK 数据包。在 SYN ACK DDoS 攻击中, 攻击者使大量 SYN ACK 数据包涌向目标。这些数据包根本不属于三向握手协议的一部分, 它们的唯一目的是打断目标的正常运作。

消耗存储资源实例：

- TearDrop P70
第二章那里写了防御方式, 可以再查查
- FORK

服务中断攻击 P60

DDoS

DDoS 和 DoS 区别及 DDoS 特点

P74 + PPT 三点

DDoS 攻击过程

P75 图 + PPT

攻占代理主机 + 向目标发起攻击

应对方式

P76 + PPT ~~-(结合 P76 看一下有什么需要补充。最好有例子，比如哪些特征字符串等)-~~

- 在数据流中搜寻特征字符串
- 利用攻击数据包的特征
- 设置防火墙
 1. 监视本地主机端口的使用情况
 2. 在防火墙服务器上放置一份 ACL（访问控制列表）来阻断这些来自一些 IP 的访问。
- 对通信数据量进行统计

反弹技术

利用反弹服务器实现攻击的技术。

区别：PPT 上四点 答的时候画图

第五章 缓冲区溢出攻击

原理概述

P78 + PPT

PPT-危害（~~利用其进行 DoS 攻击？~~没查到算了）

哪些编程习惯会导致

PPT

- 未进行缓冲区越界检查
 - 不知道内存缓冲区的总长度
 - 不能信任来自用户的数据，调用字符串处理函数等库函数时，对数组越界加以检查和限制。（比如下列例子就不知道 szName 长度）也可以见 project1-vul1
- ```
void Function(char *szName) {
 char szBuff[MAX_NAME];
 // 复制并使用 szName
 strcpy(szBuff,szName);
}
```
- 由于 strcpy 不检查内容长度，所以有溢出风险。因此 Vul1 中需要利用地点就是 strcpy()。
- 不安全的库函数调用

PPT strcpy->strncpy

见 project1-vul5 格式化字符串

漏洞在 snprintf() 函数中，因为是将 arg 作为格式化字符串拷贝（遇到格式化参数之前会先将普通字符拷贝给目标），所以可以从这里下手。除了常见的格式化字符串 '%d'、'%s' 等，'%(如: %20\$x)' 格式输出，可泄漏栈内的数据；'%n' 格式输出，可修改栈中指针指向的任意可写地址。

- 有无符号类型转换

见 project1-vul3

```
int foo(char *in, int count)
{
 struct widget_t buf[MAX_WIDGETS];

 if (count < MAX_WIDGETS)
 memcpy(buf, in, count * sizeof(struct widget_t));

 return 0;
}
```

1. 显然满足 if 条件；↵

2. 可以造成符号位溢出。即 `count * sizeof (struct widget_t)` 的结果是一个正数且大于 `buf` 的长度，造成缓冲区溢出，覆盖 `foo` 的返回地址。↵

- \*多次 free() 结合 UAF 进行攻击

eg. 假设一个对象 A 前 4 字节(0x400000)为函数 printf，释放后，恶意用户重用这个空间（使用缓冲区溢出等方式），将前 4 字节改为(0x4a0000)system 函数，然后来到漏洞的触发点，程序由于疏忽再次调用 A 的 printf，却调用了 system 函数

## 方法和步骤

看懂 PPT 例子和画图形式，答题得画图。可以看 LMPPT

把大作业 1 的六个例子回顾一下

## 防御技术

能找到对着抄就行，PPT

## Payload

### 构造流程

P82

- 准备 shellcode

### Unix&Windows

P99 地址有/x00

P101 无系统调用

### 构造 payload 注意事项

- 真实内存地址未知  
P94 使用相对 IP 的偏移地址
- Shellcode 中不能存在\x00  
P95 使用 xor 代替 mov
- 存在阻断函数\_exit(0)  
见 project1-vul6，观察\_exit(0)跳转地址，直接修改其为&shellcode



## 绕过防护方式

# 第六章 程序攻击

## 逻辑炸弹攻击

P109 + PPT 定义了解即可。

## 植入后门

### 后门和木马的区别（对照 PPT 查一下更详细的）

在 PPT“蠕虫和特洛伊木马”最后

所谓“后门”，就是程序开发人员为了改进自己设计的程序而打开的专用接口（通道），方便自己修改程序，一般具有最高权限，特征在于隐蔽性，没有**欺骗性**。木马是指利用后门或漏洞被发现非法入侵用户电脑，从事侵害用户利益的活动，不一定具有最高权限。

联系在于：都是隐藏在用户系统中向外发送信息，而且本身具有一定权限，以便远程机器对本机的控。

区别在于：木马是一个完整的软件，而后门则体积较小且功能都很单一。

### 后门的隐藏方式（对照 PPT 查一下更详细的）

- 应用级隐藏
  1. 后门程序和进程隐藏 选择一个隐秘的目录存放后门程序文件
  2. 后门程序设置隐藏标记。
  3. 定制程序名、修改图标。将自己的服务 端程序图标改成 HTML, TXT, ZIP 等各种文件的图
  4. 附着、捆绑或替换合法文件。
  5. 修改或替换管理命令。如替换“ls”“find”“du”可以实现文件和目录隐藏；替换 “ps”“top”“pidof”可以实现进程隐藏；替换 Netstat, Ifconfig 可 实现网络的连接状态隐藏；替换 Kill, Killall 可防止删除攻击者 的进程，替换 Crontab 能隐 藏攻击者的定 时启动信息，替 换 Tcpd, Syslogd 隐藏攻击者的连接信息等。
  6. 进程动态注入。将后门程序可执行代码注入正在运 行的进程中，可以极大地提高后门的生存能力。此项技术可以 很好地隐藏后门程序，并且植入后门代理程序后
- 通信状态隐藏
  1. 通信端口隐藏
  2. 将后门隐藏在合法端口，
  3. 通信连接隐藏

检测方式：通信端口检查、通信特征匹配、植入痕迹查找和完整性检查
- 内核级隐藏

LKM( Loadable Kernel Modules) 内核加载模块隐藏

检测方式：内核级后门是在内核级隐藏目录、文件、进程和通信连接等，它不修改程序二进制文件，因此 MD5 校验无法检测。内核级隐藏的一种方法是通过修改系统调用表来实现系统调用重定向从而隐藏文件、进程和通信连接，所以通过检查系统调用的内存地址就可能发现是否被植入了后门

常用查杀工具：rkhunter, chkrootkit

## 蠕虫和特洛伊木马

蠕虫的其他方法 P125

**病毒 蠕虫 木马的区别（整合一下答案即可，cy说是送分题）**

首先病毒，木马，蠕虫统称为电脑病毒。病毒（包含蠕虫）的共同特征是**自我复制、传播、破坏电脑文件，对电脑造成数据上不可逆转的损坏**。而木马独有特征是**伪装成正常应用骗取用户信任而入侵，潜伏在电脑中盗取用户资料与信息**。

病毒：编制者在计算机程序中插入的破坏计算机功能或者数据的代码，能影响计算机使用，能**自我复制**的一组计算机指令或者程序代码。

1、它必须能自行执行。它通常将自己的代码置于**另一个程序的执行路径中**。

2、它必须能**自我复制**。例如，它可能用受病毒感染的文件副本替换其他可执行文件。病毒既可以感染桌面计算机也可以感染网络 服务器。

木马：木马也称木马病毒，是指通过特定的程序来控制另一台计算机。与一般的病毒不同，**它不会自我繁殖**，也专并不“刻意”地去感染其他文件，它通过将自身伪装**吸引用户下载执行**，向施种木马者提供打开被种主机的门户，使施属种者可以任意毁坏、窃取被种者的文件，甚至远程操控被种主机。

蠕虫病毒：蠕虫病毒一种能够**利用系统漏洞通过网络进行自我传播的恶意程序**。它不需要附着在其他程序上，而是独立存在的。当形成规模、传播速度过快时会极大地消耗网络资源导致大面积网络拥塞甚至瘫痪。通过网络传播的恶性病毒，它具有病毒的一些共性，如传播性、隐蔽性、破坏性等等，同时具有自己的一些特征，如**不利用文件寄生(有的只存在于内存中)**，**对网络造成拒绝服务，以及和黑客技术相结合**。普通病毒需要传播受感染的驻留文件来进行复制，而蠕虫**不使用驻留文件即可在系统之间进行自我复制**，普通病毒的传染能力主要是针对计算机内的文件系统而言，而蠕虫病毒的传染目标是互联网内的所有计算机。

按照传输方式分类 P130

## 第七章 欺骗攻击

**PPT 上的例子着重关注一下**

### DNS 欺骗攻击

P159 **例子原理看懂 防御机制查一下**

前提条件 P159

危害 P158

防护和检测见补充部分。

### Email 欺骗攻击

#### 步骤

P162 + ppt

**SMTP 服务器需要关注的点？书+PPT 查一下详细一点**

应对方式

基于 PPT 详细一点即可

## Web 欺骗攻击

步骤

P163 + ppt 看懂例子

应对方式

基于 PPT 详细一点即可

## IP 欺骗攻击

P171 看书和 PPT 例子吧 我累了 他讲了好久 我感觉要考不在一个子网中的欺骗方法？

## 第八章—利用程序错误攻击

把书上的实例思路总结一下

## 第九章 访问控制技术

### 访问控制模式

三个维度答

争用

定时

\*物理空间—(视频中提了一下，可以大概查一下是什么维度)—

### 自主访问控制 DAC

定义可以看 LMPPT

方法：P219 一般是基于行的

类型：220

优缺点：LMPPT

### 强制访问控制 MAC

P221 + PPT 定义解释 定义可以看 LMPPT

DAC 和 MAC 的区别以及结合？结合 LMPPT 和 PPT 总一下答案

### 基于角色的访问控制技术 RBAC

P225 书上过一遍概念

P228 + PPT 相对于 DAC 和 MAC 的优点和不足

## 物理隔离

——把 PPT 上最后“物理隔离的未尽之处”详细化

P213 图 9-3

P215 网络安全隔离卡 过渡区

网络隔离卡和网卡的区别？ 见补充部分

## 隔离网闸

P216 和防火墙的区别见 PPT

## 第十章 防火墙

### 概述

P230 静态安全技术

P231 图 10-2 抽象模型在防火墙中的实际应用

### 分类

P237 两种方式对比 扫一眼就行

### 术语

- 堡垒机
- 双重宿主主机
- 周边网络

### 体系结构

P239

- 双重宿主主机体系结构
- 被屏蔽主机体系结构
- 被屏蔽子网体系结构

### 构建

- 选择体系 P251 + PPT LMPPT
- 安装堡垒机 P254 + PPT
- 数据包过滤规则 P256 + PPT

看书上例子

注意路由器的向内/向外，内部接口和外部接口的向内都是向路由器本身。

## 第十一章 入侵检测

### 概述

P287 + PPT 定义:动态网络安全技术

为什么具有实时性和自适应性？结合后面内容详细解释

具体问题可以对照 P288 图和 PPT 的原理图答

## 分类和评估

P290 每种分类方式都需要了解

LMPPT 有更详细点

集中式/分布式看 LMPPT

IDS 评估标准 P293 + PPT 误报&漏报 其他扩充答一下就行

- 准确性，指系统正确识别入侵行为的能力；
- 可靠性，指系统的容错能力和可持续运行能力；
- 可用性，指系统开销大小，对网络性能影响的大小；
- 可测试，指系统能够通过模拟攻击进行检测测试；
- 适应性，指系统易于开发和扩展；
- 实时性，指系统能够及早发现入侵企图；
- 安全性，指系统可确保自身的安全。

## 第十二章 VPN

### 概述

P305 + PPT 定义和优点（按照 PPT 示例答即可）

P306 组成和基本结构

~~VPN 为什么需要两个服务器，VPN 工作原理？整理一下~~

### 协议与实现

#### 身份验证

P309 + PPT 验证过程了解即可

#### 隧道协议

P310 + PPT 隧道的定义：针对 VPN 协议重新打包

重点了解 PPTP 和 L2TP 区别 P315 + PPT + P319 的表格

PPTP 和 L2TP 都属于第二层隧道协议，使用 PPP 协议对数据进行封装，然后添加附加包头用于数据在互联网上的传输。

- **PPTP** 点对点隧道协议
- **L2TP** 第二层隧道协议  
和 PPTP 本质区别就是从 MAC 层封装，从数据链路层开始数据包就是安全的。
- **IPSec** IP 安全协议  
定义和优势看 PPT 就行  
PPT 封装方法 常用模式 Tunnel Model  
加密过程细节都不用关注。

数据加密

## 盲猜一手

## 简答题

攻击步骤

交换式以太网和共享式以太网

- *简述以太网网络监听？* 工作原理、扫描方式等
- *如何防范网络监听？* ARP 欺骗例子及防御方法

DoS

- *外部用户针对网络连接发动拒绝服务攻击有哪几种模式？*  
DoS 分类 P57

缓冲区溢出

- *缓冲区溢出的一般目标？*  
提权；
- *要让程序跳转到安排好的地址空间执行 一般有哪些方法？*

病毒 蠕虫 木马的区别

访问控制

- DAC 和 MAC 的区别以及如何结合

VPN

- PPTP 和 L2TP 区别

## 综合题

DDoS 实例

不知道会怎么出，可能会结合攻击步骤知识点，写一个完整的攻击思路？

缓冲区溢出

方法和步骤，会偏技术

- *Printf() 有哪些漏洞？* 举例说明

欺骗攻击

- 给图解释 DNS 欺骗过程
- *IP 欺骗，他讲了很久，感觉很有可能考*

## 防火墙

重点在 数据包过滤规则 给拓扑图写过滤规则  
但其他流程答全即可

## \*入侵检测

HIDS&NIDS 区别

## 补充

一、Teardrop 防御方法：网络安全设备将接收到的分片报文先放入缓存中，并根据源 IP 地址和目的 IP 地址对报文进行分组，源 IP 地址和目的 IP 地址均相同的报文归入同一组，然后对每组 IP 报文的相关分片信息进行检查，丢弃分片信息存在错误的报文。为了防止缓存益处，当缓存快要存满是，直接丢弃后续分片报文。

## 二、信息收集的过程，结合经验和理解

1. 从一些社会信息入手：通过社工的方式，查找到目标的一些信息。可以参考 CYPPT，上面有很多信息收集的内容。
2. 找到网络地址范围：比如通过社交软件获得目标所在地，获得大致 ip 范围。通过扫描技术，地址扫描
3. 找到关键的机器地址：通过扫描技术，地址扫描
4. 找到开放端口和入口点：端口扫描技术（以上都在课本 p12）
5. 找到系统的制造商和版本：体系结构探测（课本 p13）

表4 OSI模型相应层次的安全技术和所用安全协议



| OSI七层模型             | 安全 技 术 | 安全 协 议    |
|---------------------|--------|-----------|
| 应用层<br>表示层          | 应用代理   |           |
| 会话层<br>传输层          | 会话层代理  | SOCK v5   |
| 网络层<br>数据链路层<br>物理层 | 包过滤    | IPSec     |
|                     |        | PPTP/L2TP |
|                     |        |           |